

Q: Any questions or
comments?

(Network) Security

COMP2014 Distributed Systems

Chris Greenhalgh

School of Computer Science

Contents

- Security Models and (Network) Threats
- Encryption and VPNs
- Firewalls and NAT

Q: what have you done
about security so far?

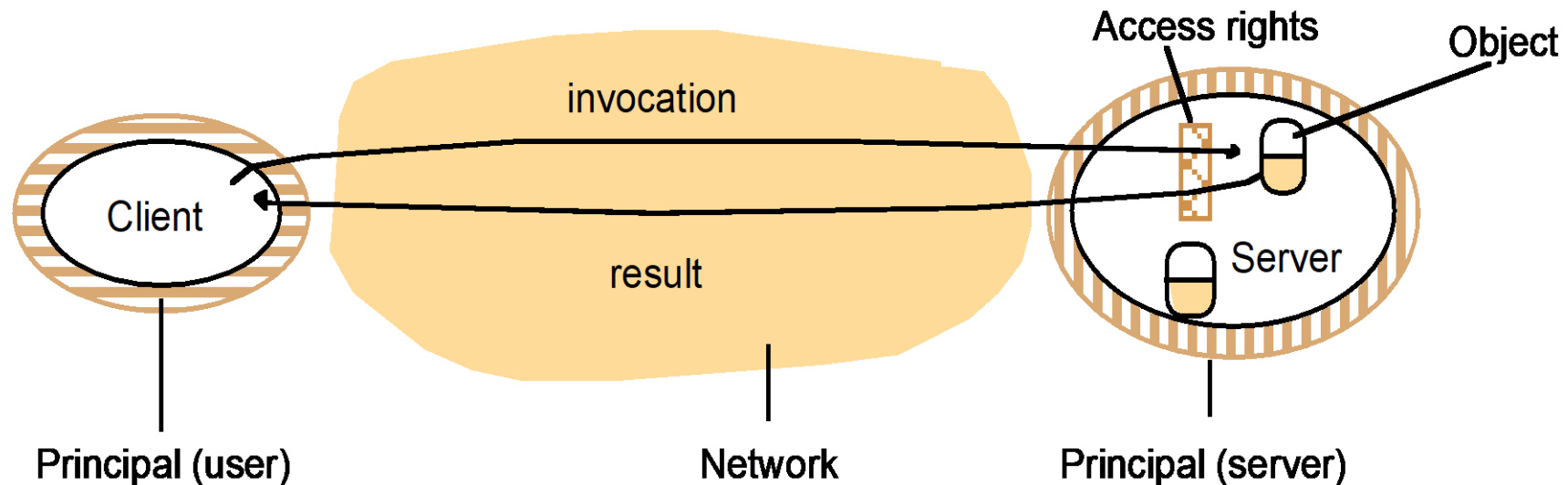
Security Models and (Network) Threats

Security model

- *The security of a distributed system can be achieved by **securing** the **processes** and the **channels** used for their interactions and by **protecting** the **objects** that they encapsulate against unauthorized access.*
 - Coulouris et al, p72
- (Note, this is mainly thinking about client-server type systems under the control of a single organization with generally trustworthy servers and users. Radically different situations will raise quite different security concerns!)

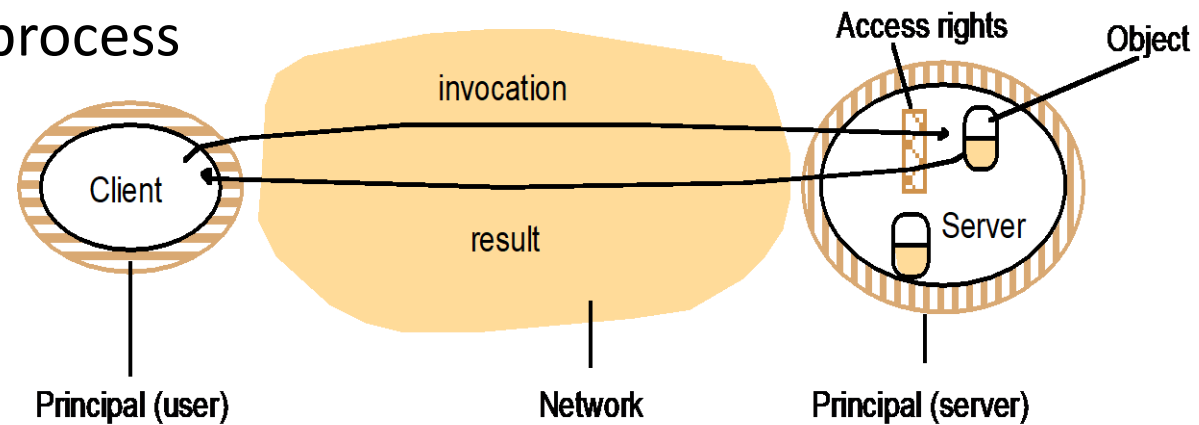
Protecting objects

- A **server** manages a collection of **objects** (or services or resources or whatever) on behalf of some **users**
- Users run **client** programs which send **invocation** requests to the server to perform **operations** on the objects



Protecting objects (cont.)

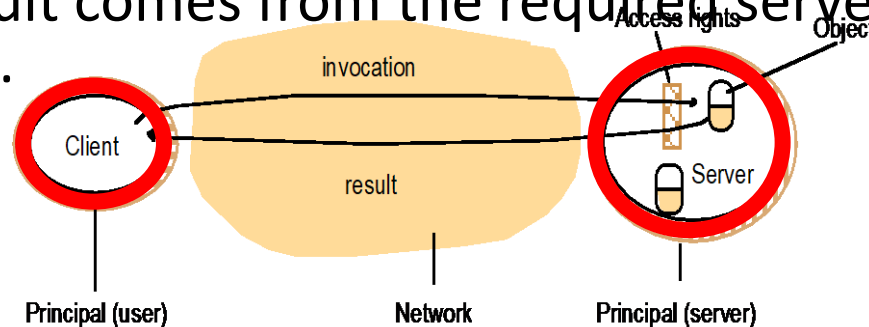
- ***access rights*** specify who is allowed to perform the operations of an object
 - for example, who is allowed to read or to write its state.
- Each request is associated with a **principal**, i.e. the authority on which it is issued
 - Which may be a user or a process



Protecting objects (cont.2)

- The server is responsible for
 - verifying the identity of the principal behind each request
 - i.e. “**authentication**” of principals
 - enforcing the access rights associated with each object
 - i.e. checking the “**authorisation**” of requests, to provide confidentiality and integrity for objects/data
 - Recording what operations were performed by whom
 - i.e. to allow subsequent “**accounting**” or “**audit**” of actions
- The client may
 - check the identity of the principal behind the server
 - to ensure that the result comes from the required server, i.e. **server authentication**.

Triple-A
(AAA) 😊

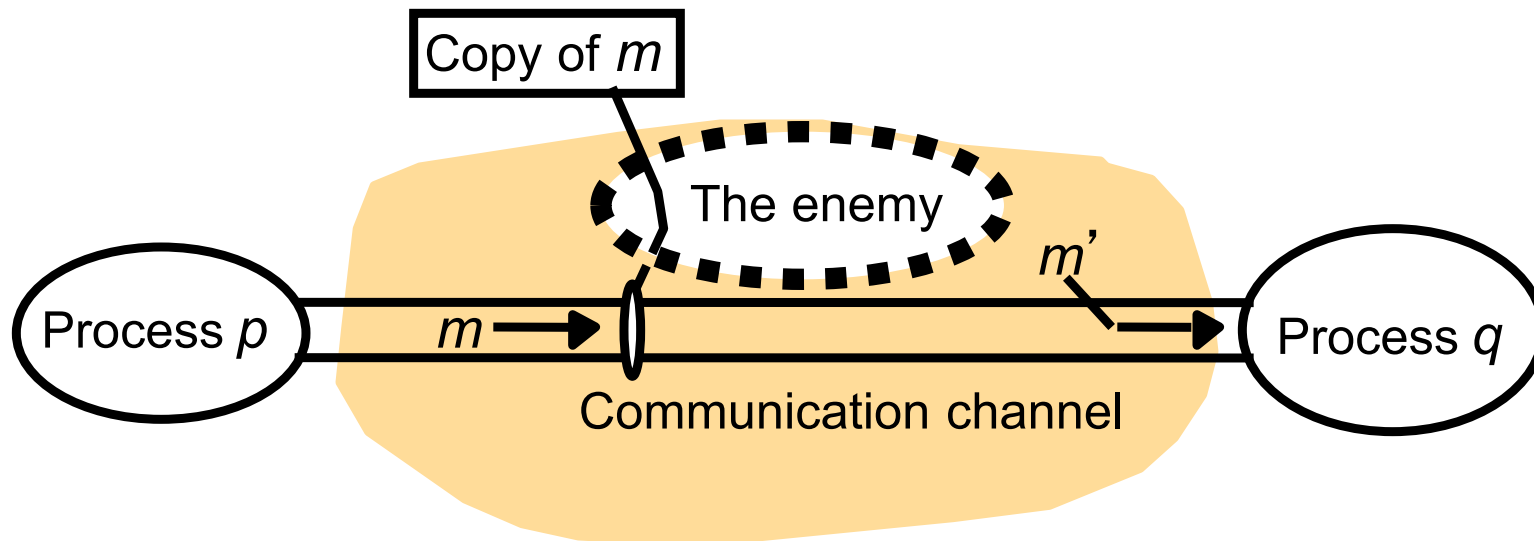


Securing processes and communication

- What do we think might be a problem?
- We need to secure the processes themselves
 - E.g. free of bugs and malicious code
 - Protected from direct interference from other processes on that machine
- But processes also interact by sending messages
 - **Messages** are exposed to attack on the network
 - Server and peer **processes** expose their interfaces, exposing them to attack from other processes
 - And client processes accept response messages

Network threat model

- To model network security **threats** we postulate an **enemy** (sometimes also known as an **adversary**) that is
 - capable of **sending** any message to any process and
 - **reading** or **copying** any message sent between a pair of processes
 - Perhaps also **modifying** or replacing any message



Types of Hackers

For example, and
for interest
(not directly
examinable)



White Hat Hackers

Ethical hackers improve security systems.



Black Hat Hackers

Malicious hackers exploit systems for gain.



Gray Hat Hackers

Blend of both Black hat & White hat Activities.

Individuals;
Cooperatives;
Organised
crime groups

Exploit tools & kits
→
Cybercrime as a
service



Script Kiddies

Inexperienced use pre-written tools.



Hacktivists

Promote political or social messages.



State-Sponsored Hacker

Conduct cyber espionage

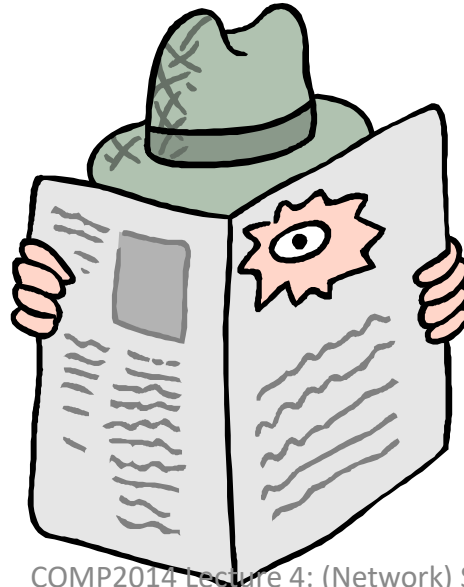


Cyber Terrorists

Create fear and disruption for political/ideological reasons.

<https://www.geeksforgeeks.org/computer-networks/types-of-hackers/>

Network exploits & attacks



Criminal Exploits and Attacks (1)

Make unauthorized requests: an unauthorized third party can send requests to an unprotected service

- I.e. they are not “supposed” to use it, but (e.g.) there is no checking

Wiretapping or eavesdropping: making a copy of packets as they traverse a network in order to obtain information

- An unauthorized third party can listen to an ongoing conversation taking place between two legitimate parties (breaching confidentiality)

Criminal Exploits and Attacks (2)

Packet Interception: removing a packet from Internet which allows substitution and **man-in-the-middle** attacks

- An intermediary can modify packets as they pass from source to destination

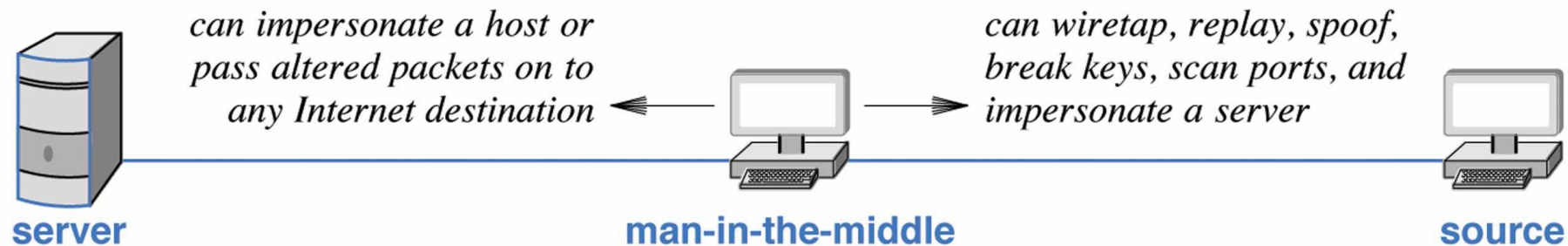


Figure 30.4 A man-in-the middle configuration and the attacks it permits.

Copyright © 2009 Pearson Prentice Hall, Inc.

Criminal Exploits and Attacks (3)

Address or Name Spoofing: impersonating a trusted host in order to intercept packets or have malicious packets accepted for processing

- For example, an attacker might
 - Fake the IP source address in a datagram
 - Get a DNS server to store the attacker's IP address against a web site's domain name
 - Send fake routing packets so that routers send traffic to a device the attacker controls

Criminal Exploits and Attacks (4)

Denial of Service (DoS): flooding a site (usually a web server) with packets to prevent the site from successfully conducting normal business

- An attacker can effectively consume all resources, meaning
 - other users experience long delays
 - legitimate users have their connections rejected

Distributed Denial of Service (DDoS)

- The attacker coordinates a large set of hosts throughout the Internet (e.g. a **botnet**) to each send a stream of packets to the same server

Criminal Exploits and Attacks (5)

And there are more, e.g.

Replay attack: re-sending copies of data stolen from the network
(even if you don't understand it)

Mobile code: sending malicious code to be run on another machine,
e.g.

Trojan, which provides useful functions but is also malicious, e.g.

Backdoor, which provides illegitimate access to the machine

Virus, which reproduces itself on other machines, consuming
resources or causing damage

Ransomware, which encrypts files, so that only the hacker can
decrypt them (usually for a fee)

...

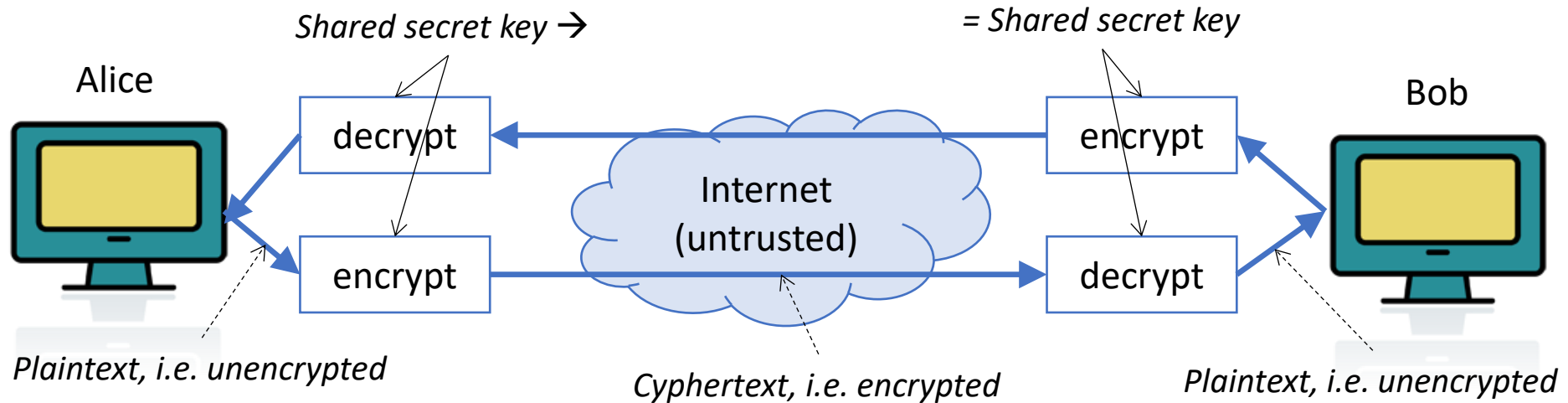
Encryption and VPNs

Encryption: A Fundamental Security Technique

- **Cryptography** is a fundamental tool in security
 - because it is used to “guarantee” data confidentiality
- A sender applies **encryption** to **scramble** the bits
 - in such a way that only the intended recipient can **unscramble** them
 - Someone who intercepts a copy of an encrypted message will not be able to extract information
- (But actually this is almost never absolute:
 - the best we can usually say is that it is “hard”, and estimate how long it might take someone to break, e.g. seconds, minutes, years, 1000s years, ...)
- Note: can be used on ANY network layer (and multiple at once)
 - E.g. layer 1/2 WiFi AND layer 3 IPSec/VPN AND layer 5 HTTPS

Private-key (symmetric) encryption

- In a **private key** system key must be kept **secret (private)**
 - Each pair of communicating entities share **a single key** that serves as both an encryption key and decryption key, i.e. **symmetric**
- For example:



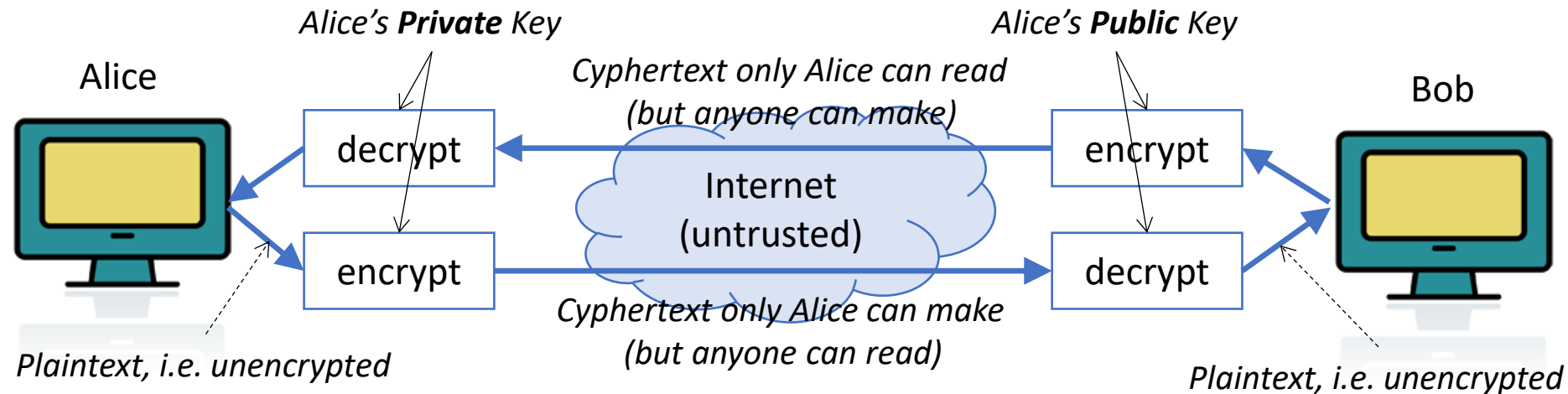
Public-key (asymmetric) encryption

- A public key system assigns each entity a **pair of keys**
 - The **private key**, is kept secret
 - The **public key**, published along with the name of the user
- Either key can encrypt a message, but the *other* key is needed to decrypt it!
 - Rely on tricky mathematical problems, e.g. RSA – factoring large numbers, Elliptic Curve Cryptography – elliptic curve discrete logarithm problem

Public-key (asymmetric) encryption applied

- Encrypting a message with that **public** key will mean that only that person can decrypt it

=> e.g. to send a new secret to the other party



- A message encrypted with a **private** key can be decrypted by anyone (with the public key)

=> Basis for **digital signatures**

About Keys...

- For both public and private key cryptography key management is an important problem, e.g.
 - How can A and B agree a new shared secret key?
 - How do you get a new secret key from A to B without eavesdropping or interception?
 - How do you know that a certain public key is A's public key?
 - How do you know that A's private key is still private?
 - What do you do if you lose a secret or private key?
 - What if the government demands to be able to decrypt these messages as well?

(Comer “Computer Networks and Internets” – for example – has more information about some of this)

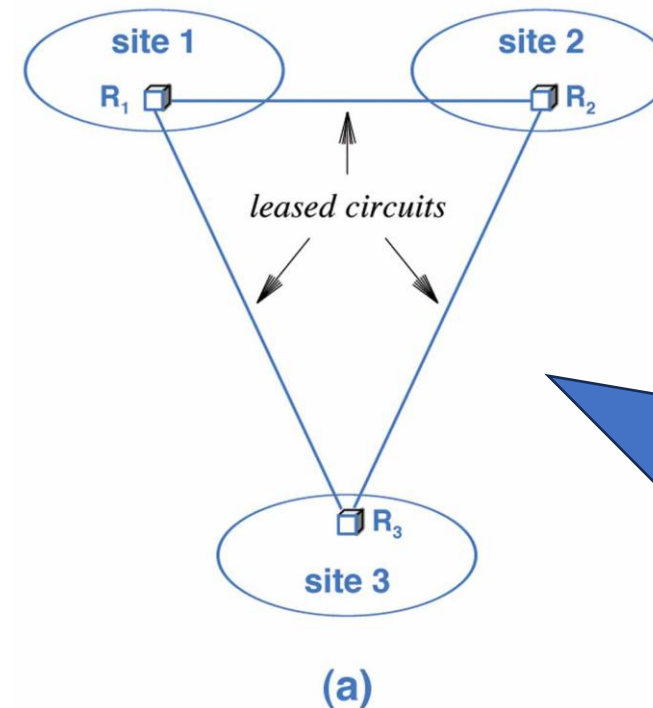
A few words about **quantum** methods...

- Quantum = “non-classical” physics ~ observations of reality that are not “either/or”
- **Quantum computing** can solve some of the “hard” mathematical problems that are the basis for many public key cryptographic algorithms, e.g. factoring large numbers
 - (but) “Quantum-resistant” cryptographic algorithms have no (currently known) quantum attack
- **Quantum communication** can allow data to be sent from A to B (e.g. using quantum entanglement) with no possibility of eavesdropping
 - E.g. **Quantum key exchange** can allow shared keys to be generated with no possibility of (undetected) interference
- (Currently these methods are experimental, expensive and limited in scale, i.e. number of q-bits)

Just for
interest: not
examinable 😊

Private Networks

- With a **Private Network** a company leases dedicated data circuits (or fibres) between each site
 - It is very hard for a third party to eavesdrop on or intercept the data on these dedicated circuits
 - But private circuits are expensive

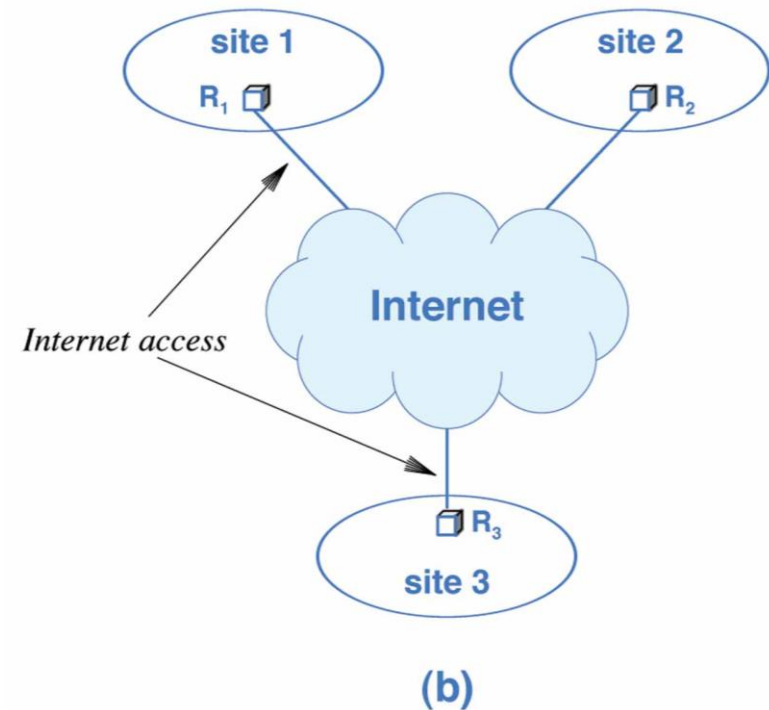


E.g. (just)
between
Jubilee Campus
and University
Park

Comer, "Computer Networks and Internetworking" © Pearson Prentice Hall Inc. 2009

Virtual Private Networks (VPNs)

- VPNs uses encryption to provide secure access to an organization's **intranet** from remote sites
 - i.e. to the internal network, behind any firewall, etc.
- With a **Virtual** Private Network traffic between sites crosses the Internet, but is encrypted
 - So that (hopefully) it is as safe as having dedicated circuits,



Comer, "Computer Networks and Internetworking" © Pearson Prentice Hall Inc. 2009

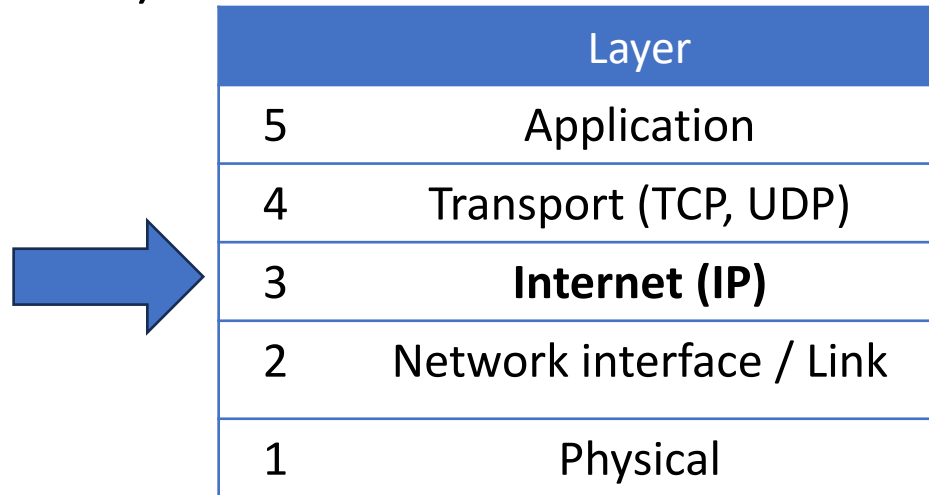
Personal VPN

- VPNs can also be used by individuals so that their computer appears to be on the VPN server's network
- This can be done by
 - **VPN client** software on the employee's computer (usually) or
 - A stand-alone device, sometimes called a **VPN router**, which the employee plugs their computer into
- The VPN router/client intercepts normal network communication and sends it over an encrypted session to the VPN server
 - Which is on the company's intranet or the UoN network or in another country...
 - Where it is forwarded as if the machine is on that network (including a source IP address on that network!)

Firewalls and NAT

Routers

- Most routers just forward packets towards their destination (largely) without changing them,
 - (See lecture 3)



- but...

Firewalls

- An organisational **firewall** is essentially a router
- It is placed between an organization and the Internet for protection
 - All packets entering/leaving the organization pass through the firewall
 - The firewall examines each packet and decides whether to forward the packet or discard it
- i.e. it is a **packet filter**

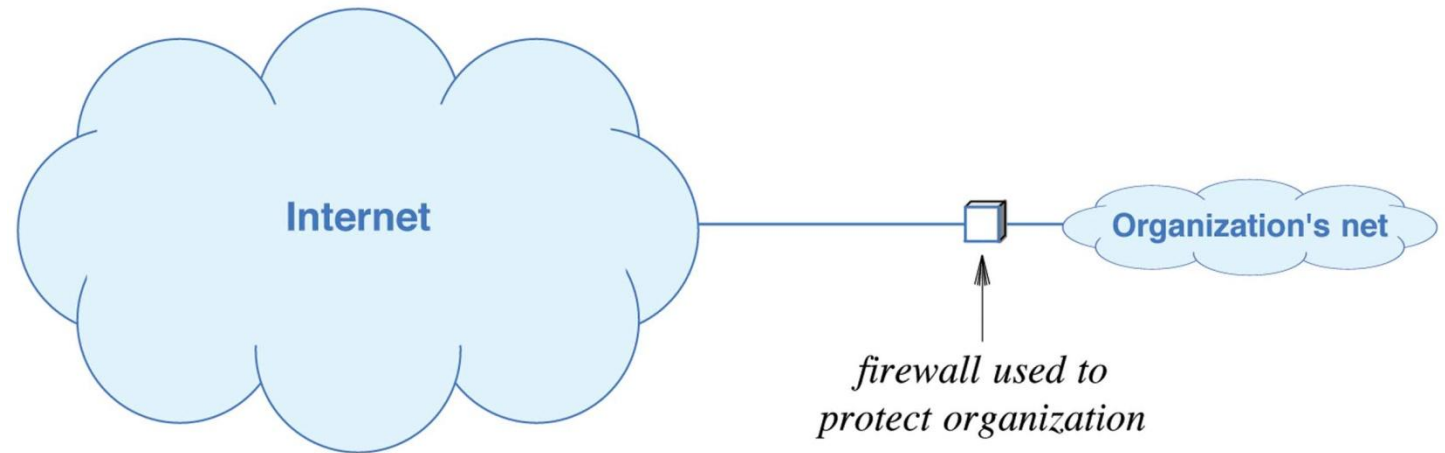


Figure 30.8. Copyright © 2009 Pearson Prentice Hall, Inc.

Firewalls (cont.)

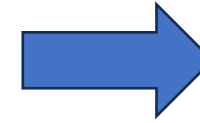
- An organizational firewall defines a **secure perimeter** that prevents outsiders from interfering with the organization's computers
 - A **firewall** was literally a fireproof physical boundary
- A machine can also have its own firewall
 - (Generally) Part of the operating system
 - Can only limit packets allowed in/out of that computer
- With virtual networks (e.g. with Cloud-hosted VMs), the virtual network itself can also have firewall-style rules
 - i.e. rules applied by the virtual network directly about which packets to carry (as well or instead of actual firewall(s))

Firewall Implementation with a Packet Filter

- A manager configures the **packet filter** by specifying which packets can pass in each direction, typically based on
 - **protocol** (e.g. TCP, UDP, ICMP),
 - **IP addresses** (source & destination host/interface/network),
 - **port numbers** (i.e. applications or services), plus
 - key header flags (esp. new vs **established** connection)
- I.e. layer 3 (Internet / IP) & layer 4 (Transport protocol / TCP / UDP)
- E.g.
 - Allow new TCP connection to port 80 on some IP address => allow HTTP connection to that machine
 - block TCP port 22 => prevent SSH access

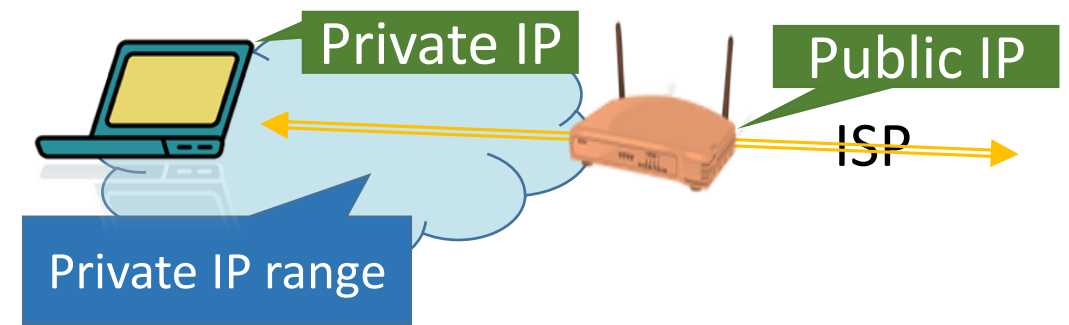
Application-Layer Firewalls

- The firewall may also examine payload
 - called Deep Packet Inspection or Application-Layer Firewall
- i.e. layer 5 / application layer
- e.g.
 - HTTP URLs (for malicious sites)
 - file content (for viruses)
- Can also be used directly in front of an application
 - E.g. Web Application Firewall (WAF): specifically for handling HTTP/HTTPS requests and blocking common website attacks



Layer	
5	Application
4	Transport (TCP, UDP)
3	Internet (IP)
2	Network interface / Link
1	Physical

NAT



- **Network Address Translation (NAT)** devices change the local IP addresses and ports when they pass on packets
- Usually part of a router - used in most home routers and many corporate networks
- From “outside” it looks like one IP address (the NAT device)
- From “inside” it is a whole **private network** and uses specific private IP addresses
- The NAT device swaps between private and public IP addresses as packets are forwarded out of and into the private network

E.g. your home network or the whole University internal network

Q: Does anyone host services from a home network? How?

NAT (cont.)

- Local (private) addresses can be reused around the world
 - Otherwise we would have run out of IPv4 addresses already
- But private IP addresses don't work from other networks
 - So by default clients on the private network can talk to servers outside it, but servers on the private network cannot be reached by clients outside it
 - Increases security!
- The NAT device can be configured to allow incoming connections to specific machines/ports
 - i.e. port forwarding
- (Or some NAT strategies can be broken or use an external server as intermediary or a local port can be exposed externally, e.g. SSH port forwarding, ngrok, VSCode remote dev/containers tools)

Summary

Security Models and (Network) Threats

Summary

- The security of a distributed system can be achieved by
 - **securing** the **processes** and the **channels** used for their interactions and by
 - **protecting** the **objects** that they encapsulate against unauthorized access.
- To model security **threats**, we postulate an **enemy** (or **adversary**) that is
 - capable of **sending** any message to any process
 - **reading** or **copying** or perhaps **modifying** any message sent between a pair of processes
- E.g. wiretapping/eavesdropping, replay, man in the middle, address or name spoofing, denial of service, ...

Encryption and VPNs Summary

- A range of technologies exist to help achieve a chosen level of security, including
- Various forms of **encryption**, both **private-key** and **public-key**, which can
 - keep data and communication secure and
 - support authentication, e.g. digital signatures
- **Virtual Private Networks**, which can mitigate the risks to a trusted device of accessing a protected network across the Internet

Firewalls and NAT Summary

- **Firewalls**, can protect networks and devices from **external** threats
 - By checking and discarding packets that cross the firewall, i.e. **packet filtering**
- **NAT** devices allow a large **private network** to appear to the rest of the Internet as a single IP address
 - Re-writes private IP addresses and ports as it forwards packets
 - But machines with private IP addresses cannot be reached from outside the private network unless specific port forwarding is used

Next

- Lecture 5: Remote Procedure Calls (RPC) and Remote Method Invocation (RMI)
- Lab 3: Java RMI